Women Techsters Sprint, Cybersecurity Track

Capstone Project Final Report (Incident Investigation Report)

NAME: Erica Gyamfuaa Fordjour

STUDENT ID: WTS/2026/169

DATE: September, 2026

TRACK: Incident Investigation

ORGANIZATION TYPE: Education (University)

ORGANIZATION NAME: Rexmi State University (RSU)

TARGET ORGANIZATION: A mid-sized university, referred to as Rexmi State University (RSU), which relies on a Learning Management System (LMS) to manage coursework, assignments, grading, and student-department communication.

PROJECT

INVESTIGATION OF A RANSOMWARE ATTACK CAUSED BY PHISHING ON A UNIVERSITY LEARNING MANAGEMENT SYSTEM.

Table of Contents

1. Executive Summary 3
2. Background and Scope 3
3. Incident Timeline 3
4. ATT&CK tactic or technique reference 6
5. Root Cause 7
6. Vulnerability Assessment 8
7. Impact 9
8. Response Actions Taken 10
9. AI Integration, Required 11
10. Recommendations 12
11. Evidence 13

Table of Figures

Figure 1 - Phishing email 13
Figure 2 – Logs 13
Figure 3 - Ransom note 14
Figure 4 - CVSS Score 15
Figure 5 - AI assistant log generation 15
Figure 6 - AI assistant MITRE ATT&CK 16
Figure 7 - Image Generation 16
12. Reflection 16

1. Executive Summary

The report is about how a ransomware attack which is an attack that encrypts or locks every file and content to demand money from stakeholders against Rexmi State University (RSU)'s Learning Management System (LMS). The LMS is a tool used by the students and staff for coursework, assignments, grading, results and student-department communications.

A phishing email which is an email from an attacker disguised as an urgent IT or administrative notice allowed an attacker to get access to the university's network. After gaining access, the attacker encrypted the LMS files overnight and, upon the next day, students and staff members could no longer access their coursework but with a ransom note instead. The main finding of the research is the ability of one phishing email without any extra protection against it to destroy an essential part of the university infrastructure. This report provides detailed information about the attack, how to recover the system back and possible ways to avoid it in the future.

2. Background and Scope

Rexmi State University (RSU) is a fictional mid-sized university where the LMS is used to manage coursework, assignments, grading and communications among its students and lecturers.

This research examines a specific ransomware incident at the institution when a phishing email allowed a hacker to gain network access and perform encryption of LMS files overnight, making the system inaccessible the next day.

3. Incident Timeline

A chronological, timestamped account of what happened.

```
20:45:02 Email: Message delivered to amonu@rsu.edu, subject "URGENT: IT Account Verification
Required"
20:45:47 WebServer: GET /verify-account.html from 41.203.18.22, response 200
20:45:52 Auth: Successful login for user amonu from 192.168.14.30
20:47:10 System: New scheduled task created on WKSTN-114 by user amonu
20:47:15 System: Registry Run key modified on WKSTN-114
20:47:22 Firewall: ALLOWED outbound connection to 185.9.2.1, port 4444
20:48:03 DNS: query for a7fk29dksla02mksd.attacker-cdn.net
20:52:00 System: Windows Event Log service stopped on WKSTN-114
21:30:11 Auth: Successful login for user amonu to DC-01 (Domain Controller)
21:30:18 System: New account added to Domain Admins group on DC-01
21:45:02 Auth: Successful login for user amonu to LMS-FileServer-1
21:45:40 Auth: Successful login for user amonu to LMS-FileServer-2
21:46:05 Auth: Successful login for user boateng to Backup-Server-1
21:46:30 System: Remote service PSEXESVC installed on LMS-FileServer-1
22:15:00 SIEM: Alert - Anomalous account activity for user amonu (multiple hosts, 45 min window)
23:00:04 System: Shadow copies deleted on LMS-FileServer-1
```

```
23:00:11 System: Shadow copies deleted on LMS-FileServer-2
23:00:47 Backup: Backup catalog purged on Backup-Server-1
23:02:15 System: Windows Server Backup service stopped on Backup-Server-1
23:31:00 System: Mass file rename operation detected on LMS-FileServer-1 (.locked extension)
00:15:00 System: Mass file rename operation detected on LMS-FileServer-2 (.locked extension)
05:00:00 System: Encryption process completed on LMS-FileServer-1 and LMS-FileServer-2
06:12:00 WebServer: GET /lms/dashboard from 192.168.22.9, response 500 (file not found)
06:25:00 WebServer: GET /lms/coursework from 192.168.22.14, response 500 (file not found)
08:00:00 System: Ransom note file detected: README_DECRYPT.txt on LMS-FileServer-1, LMS-
FileServer-2, Backup-Server-1
```

8:45 PM – The Phishing email

The staff opened the phishing message and clicked the embedded link, which took her to a credential harvesting webpage running on a compromised domain that was crafted with enough realism that she noticed nothing out of place and simply closed the browser tab. At this point, in that exact second, her credentials, MFA token, username, and password were recorded in full by the attacker.

8:47 PM – The Quiet Infiltration

Seconds after, the malicious software was loaded in the network and established persistence by scheduling tasks and registry run keys, ensuring that it survived reboots. The malware opened a connection to the attacker's command-and-control server using HTTP/HTTPS and DNS, which made the traffic indistinguishable from ordinary web browsing on the RSU's network. The firewall was modified and the windows event log was also stopped by the attacker.

9:30 PM – The Escalation

The attacker having gained a foothold, the attacker employed pass-the-hash methods to authenticate himself to other devices within the network without requiring the plaintext password. He continued his search for vulnerabilities and identified an exploitable domain controller. On a network, the domain controller is the target with the highest priority because the possession of a domain controller equals possession of control over all the computers and accounts on it. As soon as the attacker exploited the vulnerability on the domain controller, he acquired the rights of the domain administrator, making a breach of a single computer equivalent to the compromise of the whole network of the university.

9:45 PM – 10:15 PM – Spread Within the Network

Possessing the credentials of the domain administrator, the attacker spread within the network with the help of built-in Windows remote execution mechanisms rather than using malware. These actions usually manifest themselves as creating a remote service, scheduling a task on distant devices or launching a process via WMI, actions which, separately from each other, look just like regular system management. The attacker's targets were the file and infrastructure of the LMS.

10:15 PM – The Too-Late Alert

RSU's SIEM finally picked up an unusual activity event. However, at this stage, the attacker had already acquired access to domain admin privileges, the highest level of permissions available in the network environment; thus, this alert became completely ineffective against any further actions of the attacker.

11:00 PM – Blocking the Path of Return

The next step taken by the attacker involved blocking all the ways for returning. All shadow copies were deleted using a single command. Windows Server Backup were removed. In addition, all network-attached storage devices and backup folders were also identified and encrypted as they were available within the same network rather than being isolated. What happened in the case of RSU is that the destruction of their recovery opportunities guaranteed that when anyone realized about the intrusion, there would be no way out except through the attacker.

11:30 PM – 5:00 AM – Encryption

Encryption process affected all systems and connected drives associated with LMS and proceeded in real-time, while university was asleep and no one paid attention to what was going on.

6:00 AM – 6:30 AM – Initial Warnings

Students who wanted to access the LMS encountered "unable to open" errors for their files and received no explanation at that point.

8:00 AM – The Ransom Demand

By the time that the IT team was able to come in, they found that there were demands for ransom from the attackers, along with the name of the ransomware organization and the RSU victim ID number.

4. ATT&CK tactic or technique reference

Time	Stage	Tactic	Technique
8:45 PM	The Phishing email link clicked	Initial Access	Phishing (T1566)
8:45 PM	Credentials and MFA token captured	Credential Access	Steal Web Session Cookie (T1539)
8:47 PM	Loader establishes persistence	Persistence	Boot or Logon Autostart Execution (T1547)
8:47 PM	C2 traffic over HTTP/DNS	Command and Control	Application Layer Protocol (T1071)
08:52 PM	Event logs disabled and Firewall modified	Defense Impairment	Disable or Modify System Firewall (T1686) /Disable or Modify Tools: Disable or Modify Windows Event Log (T1685.001)
9:30 PM	Pass-the-hash authentication	Lateral Movement	Use Alternate Authentication Material: Pass the Hash (T1550.002)
9:30 PM	Exploiting unpatched domain controller	Privilege Escalation	Exploitation for Privilege Escalation (T1068)
9:45–10:15 PM	Remote execution across network	Lateral Movement	Remote Services (T1021)
11:00 PM	Shadow copies deleted, backups purged	Impact	Inhibit System Recovery (T1490)
11:30 PM – 8:00 AM	Files encrypted across network and Ransom note displayed	Impact	Data Encrypted for Impact (T1486)

5. Root Cause

Firstly, at 8:45 PM, a junior staff member clicked the link in a phishing email, which redirected her to a credential harvesting page on a compromised domain that was crafted well enough for her not to spot anything suspicious and just close the tab. Right after doing so, the attacker gained her credentials (username, password, and multi-factor authentication) and had full access to her account without having to brute-force or breach any kind of protection as he entered the network with his fully validated and authenticated session which was indistinguishable from hers to any system checking it. This is the first and most basic weakness in RSU's security posture, as the phishing email was not filtered by any email filtering system prior to reaching her.

Secondly, by 8:47 PM, a loader was installed on the network and established persistence through creating the task scheduler entries and modifying registry keys, which would help it remain on the network in case of restart. Then it started the encrypted HTTP and DNS communication with the attacker's remote server which made the second gap crucial. RSU didn't have the SSL/TLS inspection implemented at the time and thus its IDS/IPS systems could see only encrypted data and were unable to recognize the fact that there is a connection between this computer and attacker's remote server, as everything was happening under the cover of encryption. Finally, for further tool downloads, it used native Windows tools and therefore didn't raise any suspicion. The windows event to log event was disabled and the firewall was modified.

By 9:30 PM, the attacker had enough credentials to freely hop between different users in the network without entering any passwords, which helped him discover a domain controller that lacked a patch for known vulnerabilities. Using this information, he obtained the rights of a domain administrator almost instantly. This was the biggest failure point of the entire attack. The domain controller regulates the access of any account to any computer and user in the network, and due to this vulnerability, the compromise of one employee laptop resulted in the loss of the ability to manage the entire infrastructure in less than one hour.

From 9:45 PM to 10:15 PM, the attacker navigated towards the servers connected to the LMS via usual administrative tools, and that is how the SIEM of RSU did not detect him until it finally rang out an alert at 10:15 PM. By this time, however, the rights of a domain administrator had already been obtained by the attacker, which means that the alert came too late to prevent the damage and represents yet another failure point which is the detection mechanisms that were set up not to catch any problems until it was too late.

At 11:00 PM, the attacker started destroying every possibility of a rollback. All shadow copies were deleted with one command, and all available network-attached storage devices and backup folders were found and encrypted, because they were connected to the same network as the machines controlled by the attacker instead of being isolated and segmented separately.

From 11:30 PM to 5:00 AM, once all the possibilities of rolling back the situation were destroyed, and no monitoring mechanisms noticed anything, the encryption routine executed itself in every

machine, file-share, and drive connected to the LMS. The coursework, assignments, grades, and communication history were scrambled while the university was asleep. It was not until early birds logged in around 6:00 AM and found themselves unable to open some documents, and then IT specialists came at 8:00 AM to find the ransom notes on every screen, that the administration of RSU realized an attack had occurred.

This event did not occur because of any single mistake but because of five particular controls that were lacking or insufficient when they were each required at their exact moment

- email filtering and request validation upon entry,
- SSL/TLS monitoring during command-and-control traffic,
- patch management on the domain controller prior to privilege escalation,
- detection tuned prior to admin access by the attacker, and
- backups segmented in a way that they were protected from destruction prior to loss of recovery capabilities.

Alone, each of these weaknesses would have been tolerable. Collectively, they provided a path from a simple phishing click to complete encryption of the LMS in just under nine hours.

6. Vulnerability Assessment

CVSS score of the vulnerabilities

Metric	Value
Attack Vector	Network
Attack Complexity	Low
Attack Requirements	Low
Privileges Required	Low
User Interaction	None
Confidentiality Impact	High
Integrity Impact	High
Availability Impact	High
Base Score	8.7 (Critical)
Vector String	CVSS:4.0/AV:N/AC:L/AT:N/PR:L/UI:N/VC:H/VI:H/VA:H

The domain controller vulnerability that enabled the attacker's privilege escalation scores a 8.7 (Critical) on the CVSS v4.0 scale.

- ❖ Attack Vector is Network, since the attacker exploited it remotely.
- ❖ Attack Complexity is Low, as it required no special conditions beyond reaching the domain controller.

- Attack Requirements is None, as reaching the domain controller does not need any the attack does not depend on any deployment or executions conditions.
- Privileges Required is Low, reflecting the attacker's existing user access from the phishing compromise.
- User Interaction is None
- All three impact metrics (Confidentiality, Integrity, Availability) are High, since domain admin access grants complete control over data, systems, and uptime. This critical score underscores why patch management on assets like domain controllers is one of the highest-priority recommendations in this report.

7. Impact

This attack impacted RSU's Learning Management System entirely, alongside its files and backup associated with the system. Encrypted coursework, results, grades, and all communications between the student and the department became inaccessible from midnight to the morning after.

Applying CIA Triad to determine the impact of the damage done to the university:

The attack affected **availability** because it was the most damaged aspect. Between 11:30 PM and the discovery of the ransom note at 8:00 AM, there were absolutely no opportunities for any student and lecturer to access the LMS. Students couldn't submit their homework, professors were unable to view, edit grades and use LMS for communication, which directly interrupted the academic activities of RSU.

The **Integrity** triage was affected since files were not only deleted or hidden, but they were also modified (encrypted) as well as the user interface showing the ransom note. This made it impossible to have access to the LMS unless the encryption key provided by the attacker is acquired. Thus, once the encryption routine started running, the integrity of all affected files was breached.

The attack also affected the **Confidentiality** of the LMS because the attackers should not have been able to access the LMS data but they got access to the data and encrypted them.

8. Response Actions Taken

With the response action to the incident, the NIST Incident Response Framework (IRF) was used by RSU. According to the NIST IRF, incident responses include 4 phases, and they are **preparation**, **detection and analysis**, **containment, eradication, and recovery** and **post-incident activity**. Below is how these phases were fulfilled by the university and how they could be done better.

a. Preparation

The preparation stage is where the university was supposed to make sufficient preparation to await any future incident that may come. But the failure of the university was not assessing their security with vulnerabilities in their system which includes the lack of email filter to identify phishing attempts, no SSL/TLS inspection, unpatched domain controller and backups left accessible from the primary network instead of being isolated. Failure to do proper preparation of the university led them to the state that all they could see was a ransom note with compromised credentials.

b. Detection and Analysis

It took some time for the SIEM system to produce an alert around 10:15 PM, but even after that, the attacker had already acquired access to domain admin privileges. And the people who tried accessing the LMS in the morning got "unable to open" errors around 6:00 AM, and IT staff confirmed that there was a ransom note on their computers at 8:00 AM. At that moment, analysis of the situation starts, including identification of affected systems and backups (LMS-FileServer-1, LMS-FileServer-2, Backup-Server-1) and entry point (amonu's account) which was the scope of attack. RSU investigated to find out the root cause and the impact of the incident which we had talked about earlier.

c. Containment, Eradication, and Recovery

After the investigation, the first step the IT team took was the containment of the infected systems. Since the accounts and the domain controller were compromised, a full reset of all the accounts was implemented as well as the firewall rules to prevent any communication of the attacker with their command-and-control. Following containment of all affected systems, RSU moved to eradication of both the malware and the five key vulnerabilities that made it possible for the initial compromise of RSU's network:

- Email filtering and validation of the email requests enforced at the point of entry, thus preventing any phishing attempts reaching staff's inbox.
- SSL/TLS traffic being inspected to identify command-and-control communications sent through an encrypted channel.

- The vulnerability in the domain controller was fixed to prevent the attacker from achieving instant privilege escalation.
- Thresholds for suspicious user activity being readjusted to detect them in advance prior to obtaining admin access.
- Backup segments of data were separated from the network to ensure that even if an attacker is already present within the network, he cannot delete them.

Additionally, RSU implemented other fixes, which are patches to the firewall, IDS, and IPS with the most recent signatures to prevent future traffic from bypassing defenses by posing as HTTP and DNS traffic. With the deletion of the shadow copies and backup catalogs in the primary network, RSU did not have a local backup to restore to.

The recovery involved the use of the offline backup that had been maintained by RSU as a separate entity and hence was not affected by the attack. However, since RSU offline backups were not daily but rather monthly, the offline backup used for recovery was about a month old. While recovery was successful, all coursework and assignments completed during the last month could not be recovered. The whole system was reset, together with the account credentials and the offline backup was used to bring the system back online to its original state.

d. Post-Incident Activity

Post-incident analysis was performed as the LMS was brought back online, and all the five gaps that contributed to the root cause identified and resolved. This involved recording the timeline of the attack in its entirety as part of the institutional records, informing the management about a loss of one month of data because of the backup cycle, and advocating for the transition from monthly to regular offline backups. RSU also organized training for staff members regarding phishing attacks, with an emphasis on urgency-driven social engineering techniques, rather than phishing indicators. An incident response plan was put into place, as the result of this attack, to ensure that the next time a similar incident occurs, all containment measures are put into place within minutes.

9. AI Integration, Required

The AI used for the project is Claude AI (AI assistant by Anthropic) to assist with analysis and drafting, which was reviewed and tailored to my preference.

The first analysis involved mapping each step of the incident into the MITRE ATT&CK techniques. I provided incident details and the timeline I developed and received a suggestion of the techniques that corresponded to behaviors. The suggested technique was carefully compared with the behavior description on the MITRE ATT&CK website to confirm its applicability before it was used in the project

The second analysis involved assisting with developing a realistic log dataset for the incident in question which includes Auth, Firewall, System and Webserver logs, based on the previously developed timeline and attack steps. I then analyzed and made changes and then generated log line-by-line and identified the suspicious activities and entries.

In both cases, the AI helped me with the completion of a structured task (matching techniques and formatting logs) which was then verified and corrected according to my own understanding of the incident. The contribution of AI was significant enough to be considered a meaningful contribution to the project. The screenshots of this AI-assisted process are included below in the Evidence section.

Claude AI was used to draft and summarize the problem statement, background & context and the conclusion of the problem statement report.

Gemini AI was used to generate images that were used in the PowerPoint presentation.

10.Recommendations

The recommendation below is linked to the vulnerabilities that existed in the RSU LMS from the Root Cause section.

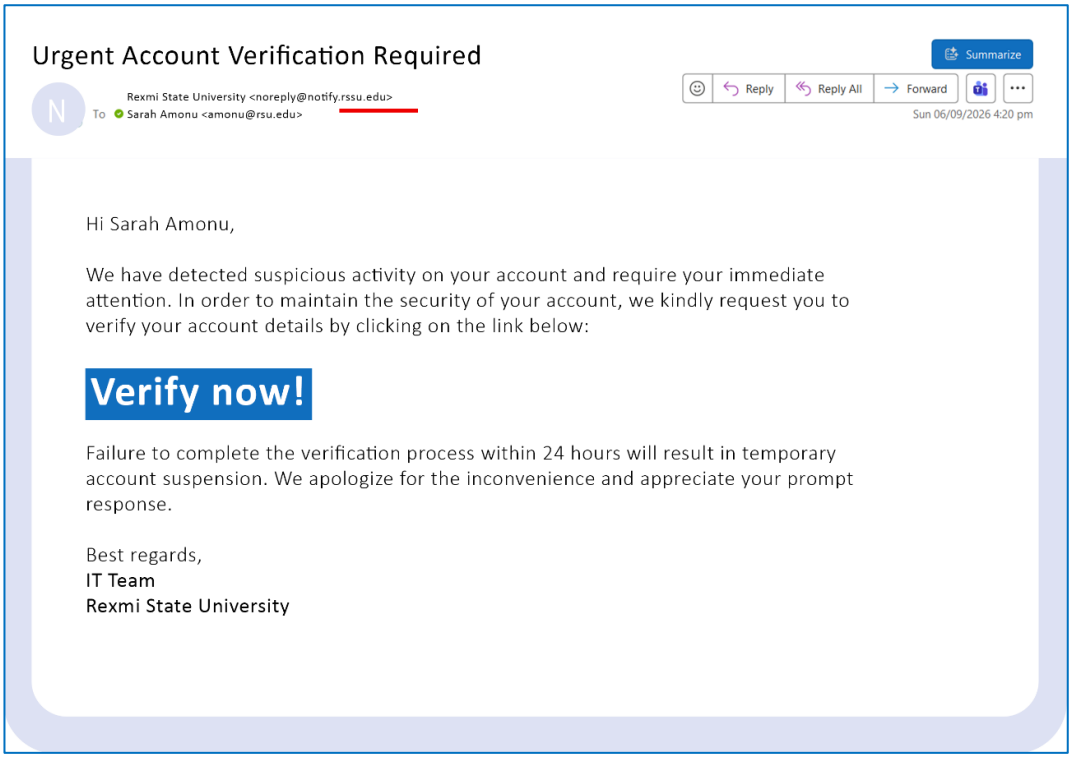
a. Email filtering can be achieved by installing an email gateway with the ability to perform URL rewriting and sandboxing to prevent malicious or phishing emails.
b. Introduction of up-to-date SSL/TLS inspection functionality for firewalls and Intrusion systems.
c. Adoption of regular patch management procedure.
d. Revision the SIEM correlations to identify signs of privilege escalation, which may include the addition of a regular user account to a Domain Admins group.
e. Adoption of the 3-2-1 back-up strategy which implies having three versions of the same data, stored on two different mediums, with one version stored off-site or air-gapped from the network, making sure that back-ups will not be accessible to attackers who have compromised the network.
f. Scheduling regular signature updates (at least weekly) for the firewall, IDS, and IPS, to recognize known malicious attack patterns and block malicious sites.
g. Increase frequency of off-line back-ups from monthly to weekly (and even daily if possible) in response to the month of coursework and grading data loss due to the previous back-up cycle adopted by RSU.
h. Develop and regularly rehearse the incident response plan for account disability, network isolation, and firewall blocking.

11. Evidence

Insert your screenshots and diagrams in this section, or reference an appendix. For each one, include a short caption explaining what it shows.

Screenshot 1: **Phishing email**

Figure 1 - Phishing email



Screenshot 2: **Logs**

Figure 2 – Logs

```
20:45:02 Email: Message delivered to amonu@rsu.edu, subject "URGENT: IT Account Verification Required"
20:45:47 Webserver: GET /verify-account.html from 41.203.18.22, response 200
20:45:52 Auth: Successful login for user amonu from 192.168.14.30
20:47:10 System: New scheduled task created on WKSTN-114 by user amonu
20:47:15 System: Registry Run key modified on WKSTN-114
20:47:22 Firewall: ALLOWED outbound connection to 185.9.2.1, port 4444
20:48:03 DNS: query for a7fk29dksla02mksd.attacker-cdn.net
20:52:00 System: Windows Event Log service stopped on WKSTN-114
21:30:11 Auth: Successful login for user amonu to DC-01 (Domain Controller)
21:30:18 System: New account added to Domain Admins group on DC-01
21:45:02 Auth: Successful login for user amonu to LMS-FileServer-1
21:45:40 Auth: Successful login for user amonu to LMS-FileServer-2
21:46:05 Auth: Successful login for user boateng to Backup-Server-1
21:46:30 System: Remote service PSEXESVC installed on LMS-FileServer-1
22:15:00 SIEM: Alert - Anomalous account activity for user amonu (multiple hosts, 45 min window)
23:00:04 System: Shadow copies deleted on LMS-FileServer-1
23:00:11 System: Shadow copies deleted on LMS-FileServer-2
23:00:47 Backup: Backup catalog purged on Backup-Server-1
23:02:15 System: Windows Server Backup service stopped on Backup-Server-1
23:31:00 System: Mass file rename operation detected on LMS-FileServer-1 (.locked extension)
00:15:00 System: Mass file rename operation detected on LMS-FileServer-2 (.locked extension)
05:00:00 System: Encryption process completed on LMS-FileServer-1 and LMS-FileServer-2
06:12:00 Webserver: GET /lms/dashboard from 192.168.22.9, response 500 (file not found)
06:25:00 Webserver: GET /lms/coursework from 192.168.22.14, response 500 (file not found)
08:00:00 System: Ransom note file detected: README_DECRYPT.txt on LMS-FileServer-1, LMS-FileServer-2, Backup-Server-1
```

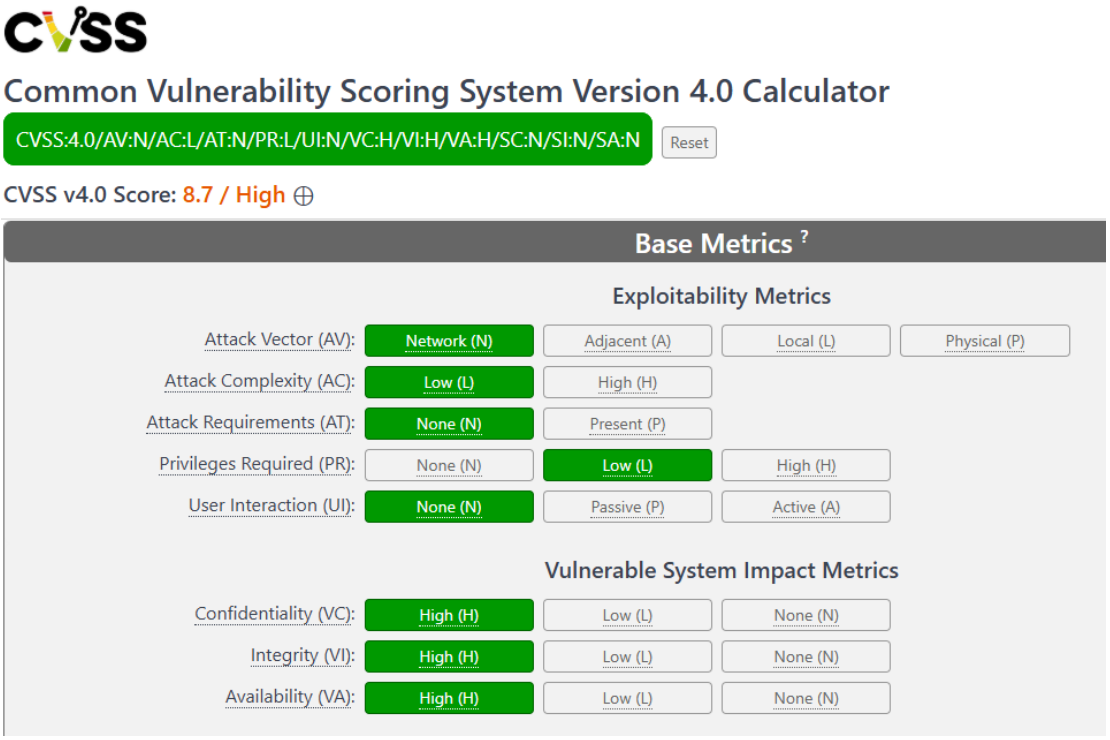
Screenshot 3: **Ransom note**

Figure 3 - Ransom note



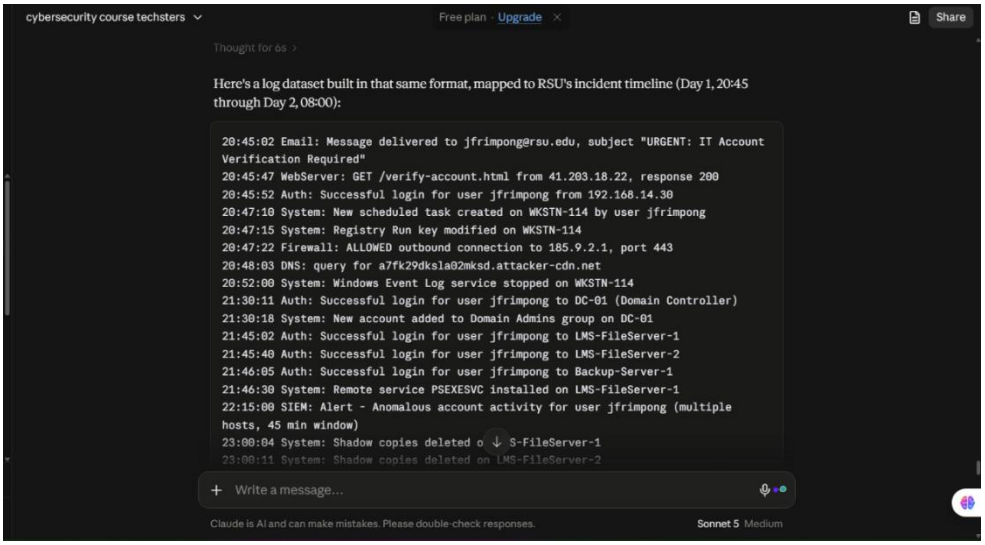
Screenshot 4: **CVSS Score**

Figure 4 - CVSS Score



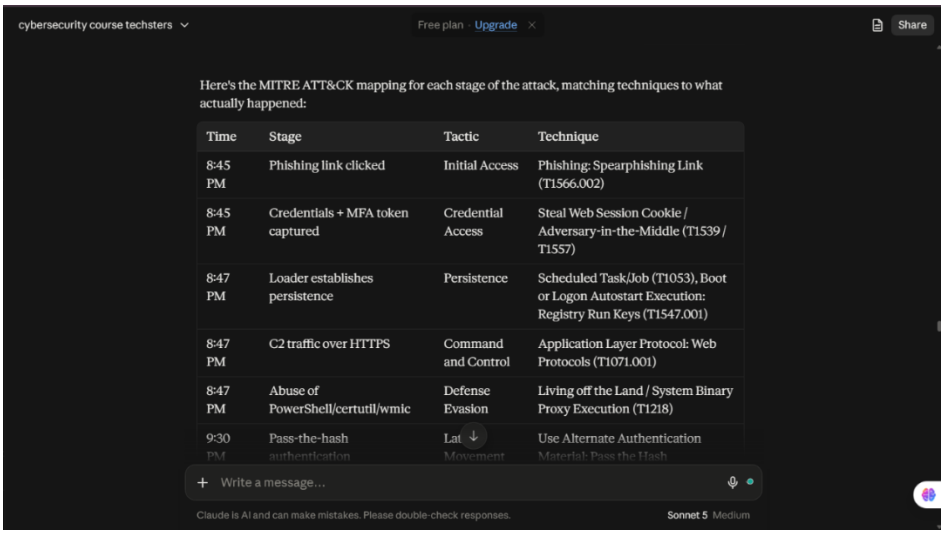
Screenshot 5: **AI assistant log generation**

Figure 5 - AI assistant log generation



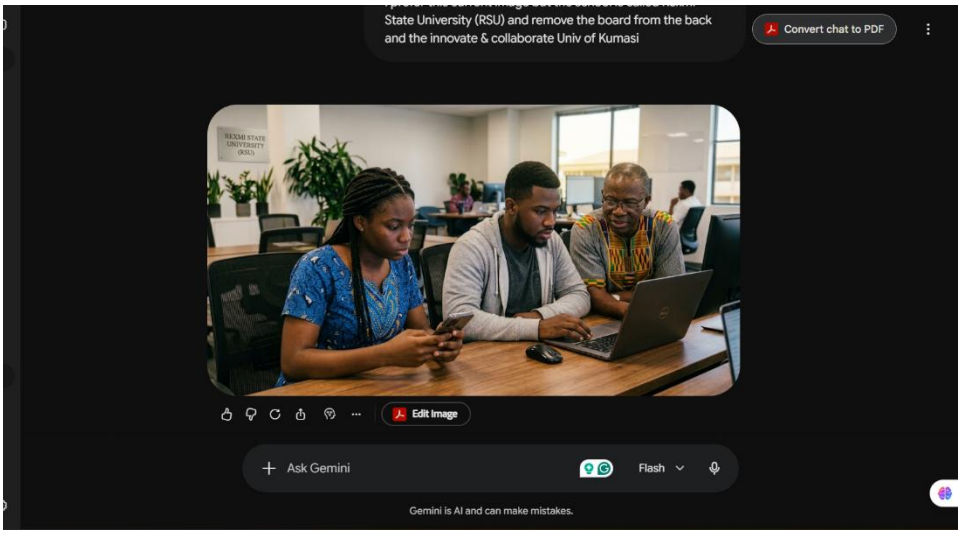
Screenshot 6: **AI assistant MITRE ATT&CK**

Figure 6 - AI assistant MITRE ATT&CK



Screenshot 7: **AI assistant Image Generation**

Figure 7 - Image Generation



12. Reflection

This project primarily focused on threat detection and analysis, incident response, and log analysis to determine the sequence of events that led from one phishing email click to ransomware deployment and then map each phase against what could or should have been detected. In terms of future improvements to the assignment process, I would create the log analysis and MITRE ATT&CK mappings earlier in the process, because having those two aspects already laid out improved my Root Cause and Impact sections.